

État de l'art – Attaques DDoS de type Carpet Bombing et mécanismes de mitigation

Rapport de synthèse – Projet de stage

Détection, caractérisation et mitigation des attaques DDoS de type carpet bombing

1. Introduction

Les attaques par déni de service distribué (DDoS) représentent aujourd'hui l'une des principales menaces pour les infrastructures réseau modernes.

Avec l'évolution des architectures cloud, des réseaux distribués et des systèmes connectés, les techniques d'attaque ont également évolué.

Parmi les formes récentes et avancées d'attaques DDoS figure le carpet bombing, une stratégie consistant à répartir le trafic malveillant sur un grand nombre d'adresses IP appartenant à un même préfixe réseau.

Contrairement aux attaques DDoS classiques qui ciblent un serveur unique, le carpet bombing vise l'infrastructure réseau dans son ensemble afin de saturer les équipements intermédiaires et les liens de communication.

Ce rapport présente un état de l'art synthétique portant sur les attaques carpet bombing, les attaques Crossfire, les techniques de mitigation au niveau du préfixe, ainsi que les méthodes de filtrage utilisées par les fournisseurs d'accès à Internet (ISP).

2. Les attaques DDoS de type Carpet Bombing

Le carpet bombing est une forme particulière d'attaque DDoS dans laquelle le trafic malveillant est distribué sur de nombreuses adresses IP d'un même sous-réseau.

L'objectif principal n'est pas de rendre indisponible un serveur spécifique, mais plutôt de saturer les équipements réseau desservant le préfixe cible, tels que les routeurs, les pare-feux ou les liens d'accès.

Cette approche présente plusieurs avantages pour les attaquants :

- elle contourne les systèmes de défense basés sur une seule adresse IP ;
- elle réduit la visibilité immédiate de l'attaque ;

- elle complique les stratégies de mitigation traditionnelles.

Les attaques carpet bombing utilisent souvent des botnets capables de générer un trafic massif réparti sur des centaines d'adresses IP de destination.

Le trafic peut prendre différentes formes :

- TCP SYN flood ;
- UDP flood ;
- amplification DNS ou NTP ;
- ICMP flood.

Les principales caractéristiques observées dans ces attaques sont :

- un fort taux de paquets par préfixe ;
- une dispersion importante des destinations ;
- une augmentation anormale du fan-out ;
- une forte entropie dans la distribution des IP ciblées.

La littérature récente montre que ces attaques sont particulièrement difficiles à détecter car chaque hôte individuel reçoit parfois un volume de trafic relativement faible, insuffisant pour déclencher les mécanismes classiques de défense.

3. Les attaques Crossfire

Les attaques Crossfire constituent une autre catégorie avancée d'attaques DDoS.

Introduites dans les travaux de recherche autour des attaques réseau furtives, elles visent à perturber la connectivité d'une région ou d'un service en saturant des liens critiques du réseau.

Le principe du Crossfire repose sur :

- l'identification préalable des liens stratégiques ;
- l'utilisation de bots générant un trafic apparemment légitime ;
- l'envoi du trafic vers des serveurs leurres appelés decoy servers.

Contrairement aux attaques volumétriques classiques, les paquets utilisés dans Crossfire ressemblent à du trafic normal, ce qui rend leur détection plus complexe.

Les attaquants exploitent la topologie du réseau afin de provoquer une congestion ciblée sur certains chemins.

Les similitudes entre Crossfire et carpet bombing sont nombreuses :

- distribution du trafic ;
- difficulté de détection ;
- ciblage de l'infrastructure réseau ;
- utilisation de comportements furtifs.

Cependant, Crossfire met davantage l'accent sur la saturation des liens réseau spécifiques, tandis que carpet bombing cible principalement les préfixes IP et les équipements associés.

4. Mitigation des DDoS au niveau du préfixe

Les mécanismes de mitigation traditionnels des DDoS reposent généralement sur un filtrage par adresse IP.

Cependant, cette approche devient inefficace face aux attaques distribuées sur un grand nombre de destinations.

Les recherches récentes proposent donc des mécanismes de défense au niveau du préfixe réseau.

Les approches de mitigation par préfixe consistent à surveiller et contrôler le trafic associé à un sous-réseau entier plutôt qu'à une machine individuelle.

Les principales techniques incluent :

- le rate limiting par préfixe ;
- le blackholing contrôlé ;
- le traffic shaping ;
- le reroutage vers des centres de scrubbing ;
- la détection basée sur l'entropie.

Le rate limiting permet de limiter le débit maximal autorisé vers un sous-réseau afin d'éviter la saturation des équipements réseau.

Le traffic shaping ajuste dynamiquement les flux afin de préserver les communications légitimes.

Certaines solutions utilisent également des techniques basées sur l'apprentissage

automatique afin de détecter des comportements anormaux à partir de métriques telles que :

- le nombre d'IP ciblées ;
- la distribution des paquets ;
- la fréquence des connexions SYN ;
- les variations temporelles du trafic.

Les méthodes les plus récentes combinent des approches statistiques et des modèles de machine learning comme :

- Isolation Forest ;
- Random Forest ;
- clustering K-means ;
- réseaux de neurones.

Ces mécanismes permettent d'améliorer la précision de détection tout en réduisant les faux positifs.

5. Techniques de filtrage au niveau des ISP

Les fournisseurs d'accès à Internet (ISP) jouent un rôle essentiel dans la mitigation des attaques DDoS à grande échelle.

Étant positionnés au cœur des infrastructures réseau, ils disposent d'une visibilité importante sur le trafic transitant entre les différents systèmes autonomes (ASN).

Les principales techniques de filtrage utilisées par les ISP sont :

- ACL (Access Control Lists) ;
- filtrage BGP FlowSpec ;
- Remote Triggered Black Hole (RTBH) ;
- filtrage basé sur les signatures ;
- systèmes de scrubbing distribués.

Le BGP FlowSpec permet de diffuser dynamiquement des règles de filtrage à travers le réseau afin de bloquer certains types de trafic malveillant.

Le RTBH consiste à rediriger le trafic destiné à une cible vers une route nulle afin d'éviter la saturation du réseau.

Les centres de scrubbing sont également largement utilisés.

Ils analysent le trafic entrant, éliminent les paquets malveillants et ne transmettent que le trafic légitime vers la cible.

Certaines recherches récentes proposent des approches coopératives entre plusieurs ISP afin de partager des informations de threat intelligence et améliorer la réactivité face aux attaques distribuées.

6. Mesure du trafic et caractérisation des attaques

La mesure et la caractérisation du trafic réseau constituent des étapes essentielles dans la compréhension des attaques DDoS modernes.

Les analyses reposent généralement sur :

- des captures réseau (pcap) ;
- des statistiques de flux NetFlow ;
- des métriques temporelles ;
- des analyses d'entropie ;
- des modèles comportementaux.

Dans le cadre du carpet bombing, plusieurs indicateurs sont particulièrement pertinents :

- dispersion des destinations IP ;
- évolution du fan-out ;
- augmentation soudaine du trafic SYN ;
- taux de paquets par préfixe ;
- variations de l'entropie des destinations.

Les visualisations sous forme de séries temporelles, heatmaps ou graphes permettent de mieux comprendre la dynamique des attaques.

Les outils fréquemment utilisés incluent :

- Wireshark ;
- tcpdump ;
- Scapy ;
- Mininet ;
- bibliothèques Python de data science.

L'utilisation de datasets réalistes est également importante pour entraîner et évaluer les modèles de détection.

7. Conclusion

Les attaques DDoS de type carpet bombing représentent une évolution importante des menaces réseau modernes.

En distribuant le trafic malveillant sur un grand nombre d'adresses IP d'un même préfixe, elles contournent les mécanismes de défense classiques basés sur des cibles uniques.

Les travaux de recherche récents montrent que les approches de mitigation au niveau du préfixe, combinées à des techniques d'analyse comportementale et de machine learning, offrent des résultats prometteurs.

Les ISP jouent également un rôle clé grâce aux mécanismes de filtrage avancés comme BGP FlowSpec et les centres de scrubbing.

Enfin, les attaques Crossfire démontrent que les attaquants exploitent désormais la topologie réseau et les infrastructures de communication elles-mêmes.

Ces évolutions nécessitent des solutions de détection et de mitigation plus intelligentes, collaboratives et adaptatives.

Références

- [1] A. Srivastava, B.B. Gupta, A. Tyagi, Anupama Sharma, and Anupama Mishra, "A Recent Survey on DDoS Attacks and Defense Mechanisms", Springer CCIS 203, pp. 570–580, 2011.
- [2] S. Kandula, D. Katabi, M. Jacob and A. Berger, "Botz-4-Sale: Surviving Organized DDoS Attacks", USENIX.
- [3] M. S. Kang, S. B. Lee and V. D. Gligor, "The Crossfire Attack", Proceedings of the IEEE Symposium on Security and Privacy (SP), pp. 127–141, 2013.